SERVMS Implementation Audit

What is built, what is half-built, and what is missing — traced through the interface, the API, and the database, then reconciled against each other. The evidence base behind the SERVMS User Manual and Training Manual.

Method UI → API → controller → service → database · **Scope** branch `servms-updates` · **Findings** 31

CONTENTS

1 Method & Scorecard
2 Compliance Matrix
3 Fully Implemented
4 Partially Implemented
5 Backend Without UI
6 UI Not Connected
7 Not Implemented
8 Inconsistencies
9 Dormant Data
10 Priority Findings
11 Documentation Coverage

SECTION 1

Method and Scorecard

1.1 What was examined

Every module was traced along the full path — **screen → client API call → route → permission guard → controller → service → SQL** — in both directions. Forward, to confirm each screen control reaches a working endpoint. Backward, to find endpoints and database columns that no screen ever reaches.

SURFACE	EXTENT
Screens	31 page components, 12 modal and shared components
Client API definitions	19 modules
Server routers	18 routers, 127 TypeScript files
Database	38 tables
Permission model	8 roles × 14 modules × 6 actions, plus 7 role-named overrides

1.2 Classification

VERDICT	CRITERION
`Implemented`	A user can reach it, use it, and it writes correctly to the database.
`Partial`	Reachable and usable, but a documented aspect is absent, inconsistent, or unreliable.
`Backend only`	The endpoint works but no screen calls it.
`Missing`	No working path exists, or a visible control does nothing.

1.3 Scorecard

14 AREAS FULLY IMPLEMENTED

6 AREAS PARTIALLY IMPLEMENTED

4 AREAS MATERIALLY MISSING

3 HIGH-SEVERITY FINDINGS

13 MEDIUM-SEVERITY FINDINGS

15 LOW-SEVERITY FINDINGS

HEADLINE ASSESSMENT

SERVMS is a substantially complete system. Its core — the permission model, division scoping, the ID card issue-and-sign workflow, both Action Taken Report chains, and the penalty money trail — is implemented thoroughly and defended consistently at both the browser and the server. The audit trail captures before-and-after values across every write path.

The gaps cluster in three places rather than spreading evenly: **record maintenance after creation** (no edit screen for vendors or users), **outbound communication** (no channel exists behind the notification preferences), and **account lifecycle** (deactivation does not deactivate). The first two are absences; the third is a correctness defect and the single most consequential finding in this report.

SECTION 2

Compliance Matrix

AREA	IMPLEMENTED	PARTIAL	MISSING	DOCUMENTATION STATUS
Authentication	✓	Status not checked at sign-in; no forgot-password	Self-service reset; MFA; lockout	Documented §3 with both gaps flagged
Session management	✓	—	Idle timeout; server-side revocation	Documented §3.5
Roles & permissions	✓	—	—	Full matrix documented §6.3
Division scoping	✓	—	—	Documented §6.2 and per module
Dashboard	✓	Licence-fee drill-through does not reproduce its figure	—	Documented §4 with the mismatch flagged
Location & unit masters	✓	Clusters have no edit action	—	Documented §9.4
Contractor management	✓	Edit form narrower than registration; no delete in UI	—	Documented §10.3, §10.5
Vendor management	✓	**No edit or delete screen**	—	Documented §11.4 prominently
ID card & QR	✓	Per-card status link has no UI	—	Documented §12
Public verification	✓	—	—	Documented §12.7 with the privacy exposure flagged
Vendor renewals	✓	**No permission checks at all**	—	Documented §13 with a prominent warning
Complaints & ATR chain	✓	Assignment to a person has no control	—	Documented §14
Inspections & ATR chain	✓	Assignment to a person has no control	—	Documented §15
Penalties & recovery	✓	—	—	Documented §16
Approval workflows	✓	—	—	Six workflows documented; Training Manual §6
Document upload	✓	Uploads publicly readable; no delete for vendor documents	—	Documented §21 with the exposure flagged
Search & filter	✓	Per-module only	**Global search**	Documented §5.1 as non-functional
Sorting	—	Server-side default ordering only	User-selectable column sort	Documented §7.1

AREA	IMPLEMENTED	PARTIAL	MISSING	DOCUMENTATION STATUS
Reports & builder	✓	—	—	Documented §17
Excel export	✓	Two “Excel” buttons produce CSV; two exports capped at 2,000	—	Documented §18.4
Excel import	✓	Only Stations importable as a master	Vendor, contractor, unit, user import	Documented §18.1
Audit logs	✓	Eight filter actions are never written	**Login / logout auditing**	Documented §20.4 prominently
Notifications — in-app	✓	Read state is per-browser, not per-user	—	Documented §19.3
Notifications — outbound	—	Preference panel present but inert	**Email, SMS, push**	Documented §19.4 prominently
Validation	✓	No format checks on mobile, PAN, GSTIN, Aadhaar beyond length	—	Documented per module
Error handling	✓	—	—	~60 messages catalogued §22
Configuration / settings	—	—	**No settings screen exists**	Documented §5.3
Help / support	—	—	**No help screen exists**	Documented §5.3
Admin module (dropdowns)	—	Permission and API exist	**No management screen**	Documented §5.2, Training §7.4

SECTION 3

Fully Implemented

Verified end to end: a screen control reaches a guarded endpoint, the service performs the operation, the database is written, and the audit trail records it.

CAPABILITY	EVIDENCE
JWT authentication	bcrypt cost 12; 12-hour token; expiry distinguished from tampering; 401 clears the session and redirects
Two-layer permission enforcement	Route guard on the browser plus an independent server guard on every endpoint; Super Admin HQ bypass implemented identically on both sides
Division / self / assignee scoping	Applied to list queries and to single-record reads; out-of-scope reads return 404 rather than 403, so scope cannot be probed
Admin-tier delegation	Only Super Admin HQ may create, edit, or disable Super Admin HQ, HQ Admin, or Divisional Admin accounts; checked against both current and requested role
Role & permission matrix administration	14 × 6 grid, editable and persisted; changes take effect without re-login
Dashboard aggregation	Five group cards, seven alert panels, HQ division toggle, five filters, three chart types, drill-through with interaction tracking, automatic refresh
Vendor onboarding	Five-step wizard; conditional station and unit requirements derived from live data; both certificate numbers enforced; date-order validation
ID card issue → sign → QR → PDF	One approval applies the signature image, builds the QR text, renders the PDF, stamps the issue date, and activates the card; two formats; division-scoped signing
Public QR verification	Unauthenticated endpoint; renders status, vendor data, validity, and verification steps; stamps a last-checked time on every scan
Complaint ATR chain	Submit → review → decide → close, with send-back; stage-skipping refused; submitter-only editing; full status history
Inspection ATR chain	Draft → submit → review → decide → close, plus return-to-inspector; author-only submission enforced
Penalty money trail	Three independent state families; forward-only recovery; part-payment and full-payment rules; separate recovery verification with resubmission
Report builder	Eight modules; type-aware operators; grouping and aggregation; preview; CSV and true XLSX export; templates with sharing and usage tracking; export history
Audit trail	28 controllers write entries carrying user, role, division, action, module, record, before, after, details, IP, and user agent; passwords stripped; a failed audit write never blocks the operation

SECTION 4

Partially Implemented

F-01 Vendor Renewals is not permission-checked — HIGH

WHAT EXISTS	The full renewal workflow — create, list, approve, reject — works, and approval correctly pushes the new expiry onto the vendor record and reactivates them.
WHAT IS ABSENT	The renewal router applies authentication only. No endpoint carries a permission guard, so **any authenticated user** — Inspector, Dealing Section, Complaint Cell — can create, approve, and reject renewals. The screen's own Approve and Reject buttons are not permission-gated either. Every other module in SERVMS guards both layers.
CONSEQUENCE	An expired vendor can be returned to Active service by any signed-in user. This is the widest privilege gap in the system.
REMEDY	Add `requirePermission("vendor_management", …)` to each renewal route — view on the reads, create on the POST, approve/reject on the PATCH — and gate the screen's buttons to match.
DOCUMENTED	User Manual §6.4 and §13, both as prominent warnings.

F-02 No edit or delete screen for vendors — MEDIUM

WHAT EXISTS	Working update and delete endpoints, correctly guarded, with matching client API definitions already written.
WHAT IS ABSENT	No screen invokes either. The client hooks `useEditVendorMutation` and `useDeleteVendorMutation` are defined and never referenced. Only status, the two verifications, and unit or contractor transfers can be changed after onboarding.
CONSEQUENCE	Twelve captured fields — name, father's name, date of birth, Aadhaar, mobile, address, blood group, vendor type, photograph, signature, and both validity dates — are permanent from the moment the wizard is submitted. A misspelled name needs a database change.
REMEDY	Add an edit view reusing the wizard's field definitions. The endpoint and its validation already exist, so this is UI work only.
DOCUMENTED	User Manual §11.4; Training Manual §7.1 as the “golden rule”.

F-03 No edit, delete, or approval screen for users — MEDIUM

WHAT EXISTS	Working endpoints for full update, partial update, delete, approve, and reject — all correctly guarded, including the Admin-tier check.
WHAT IS ABSENT	User Management offers only Toggle, Reset Password, and Transfer. No client API definition exists for edit, delete, approve, or reject, so no screen could call them. The `pending_approval` user status has no interface at all.
CONSEQUENCE	Once created, a user's name, Employee Number, username, HRMS ID, designation, grade, email, mobile, station, signing authority, and signature are permanent. Card Signing Authority in particular can never be revoked through the interface.
REMEDY	Add an edit dialog mirroring Add New User, plus an approval queue for pending accounts. Endpoints and validation already exist.
DOCUMENTED	User Manual §7.3.

F-04 Assignment to a named individual has no control — MEDIUM

WHAT EXISTS	Both the complaint and inspection assignment endpoints accept an assignee, validate it, store it, and join it back for display. The assignment history and the detail views are ready to show an assignee name.
WHAT IS ABSENT	Both assignment dialogs offer a target unit and remarks only. No control sets the assignee, so it is always empty.
CONSEQUENCE	Work can be routed to units but never to people. The Dealing Section's assignee-scoped visibility therefore rests on unit assignment alone, and personal accountability for an assigned case is not recorded.
REMEDY	Add an optional assignee picker to both dialogs, populated from users in the target unit's division.
DOCUMENTED	User Manual §14.6 and §15.6.

F-05 Contractor edit form is narrower than registration — MEDIUM

WHAT EXISTS	Nine fields are editable: contact, mobile, email, licence number and validity, registration fee, award date, tenure, and contract value.
WHAT IS ABSENT	Company name, PAN, GSTIN, registered address, and division are captured at registration and appear on no edit form — even though the update endpoint accepts and validates all five.
CONSEQUENCE	A statutory identifier entered incorrectly at registration cannot be corrected. Division in particular cannot be changed, so a contractor registered against the wrong division stays there.
REMEDY	Extend the edit form to the fields the endpoint already accepts.
DOCUMENTED	User Manual §10.3.

F-06 Clusters cannot be edited — LOW

WHAT EXISTS	A working cluster update endpoint and a defined `useEditClusterMutation` hook.
WHAT IS ABSENT	The Clusters tab renders a Remove action only. The hook is never referenced. Units, Stations, and Trains all have edit actions.
CONSEQUENCE	Changing a cluster's name, type, or membership requires removing and recreating it, breaking any unit that references it.
REMEDY	Add an edit action to the Clusters tab. The endpoint and hook already exist.
DOCUMENTED	User Manual §9.4.

SECTION 5

Present in the Backend, Absent from the UI

Working, guarded endpoints that no screen reaches. Each is dead weight unless a screen is added or the endpoint is retired.

ENDPOINT	CAPABILITY	CLIENT HOOK	SEVERITY
`PUT /users/:id` `PATCH /users/:id`	Edit a user	None defined	MEDIUM
`DELETE /users/:id`	Delete a user	None defined	LOW
`POST /users/:id/approve` `POST /users/:id/reject`	Approve or reject a pending account	None defined	MEDIUM
`PATCH /users/:id/change-password`	Self-service password change	None defined	HIGH — SEE F-08
`PATCH /vendors/:id`	Edit a vendor	Defined, unused	MEDIUM
`DELETE /vendors/:id`	Delete a vendor	Defined, unused	LOW
`DELETE /vendors/:id/documents/:docId`	Delete a vendor document	Defined, unused	LOW
`GET /vendors/:id/verification`	Dedicated verification read	Defined, unused	LOW
`DELETE /contractors/:id`	Delete a contractor	Defined, unused	LOW
`PATCH /idcards/:vendorId/status-link`	Per-card status spreadsheet link	Defined, unused	LOW
`PATCH /clusters/:id`	Edit a cluster	Defined, unused	LOW
`GET /penalties/notifications`	Penalty-specific notification feed	Defined, unused	LOW

`POST /dropdowns`
`PATCH /dropdowns/:id`
`DELETE /dropdowns/:id`
`POST /dropdowns/:id/activate`
	Managed dropdown administration — the entire `admin_module` permission	Defined, unused	MEDIUM — SEE F-07

`GET /penalties/:id`, `/units/:id`, `/clusters/:id`, `/renewals/:id`	Single-record reads	Some defined, none used — screens read from the list payload	LOW

F-07 The Admin Module permission governs nothing reachable — MEDIUM

WHAT EXISTS	`admin_module` is one of the 14 modules in the permission matrix, is granted to Super Admin HQ and HQ Admin, and guards four working dropdown-administration endpoints.
WHAT IS ABSENT	No screen calls any of them. The client's dropdown API is read-only in practice — the only category read anywhere is `contract_category`, on the unit form. Complaint and inspection type masters have their own screens, guarded by role name rather than by this permission.
CONSEQUENCE	A row in the permission matrix that changes nothing, and a managed-dropdown facility that can only be administered by direct API call. Contract categories in particular cannot be maintained by any user.
REMEDY	Either add a dropdown administration screen behind this permission, or remove `admin_module` from the matrix so it does not imply a capability that is unreachable.
DOCUMENTED	User Manual §5.2; Training Manual §7.4.

F-08 Temporary passwords can never be replaced by their owner — HIGH

WHAT EXISTS	An approved reset generates a temporary password, stores its hash, and flags the account. The change-password endpoint exists, validates a current and new password, and clears the flag on success.
WHAT IS ABSENT	No screen calls it and no client hook is defined. The temporary-password flag is set and never read: nothing prompts the user, and nothing blocks normal use.
CONSEQUENCE	A system-generated temporary password, transcribed by hand from a banner and relayed verbally, becomes the account's permanent credential. Changing it again requires a fresh two-person reset. Over time, a growing share of accounts are secured by short machine-generated strings that have been spoken aloud.
REMEDY	Add a change-password screen, and force it on next sign-in whenever the temporary flag is set. The endpoint and validation already exist.
DOCUMENTED	User Manual §7.4 and §3.4; Training Manual EX–07 makes trainees discover it deliberately.

SECTION 6

Present in the UI, Not Properly Connected

Visible controls that do not do what a user would reasonably expect.

F-09 The global search field is decorative — MEDIUM

WHERE	Application top bar, on every signed-in screen.
BEHAVIOUR	Rendered with a placeholder reading “Search across SERVMS…” and no value binding, no change handler, and no submit handler. It accepts typing and does nothing with it.
CONSEQUENCE	The most prominent control in the frame is inert. Users type into it and conclude the system is broken or slow. No cross-module search exists anywhere.
REMEDY	Implement it, or remove it. Leaving a visibly inert search field in the frame of every screen actively misleads.
DOCUMENTED	User Manual §5.1 and §22.7; Training Manual EX–24 step 1.

F-10 “Forgot Password?” is a dead anchor — MEDIUM

WHERE	Login screen, beside the password field.
BEHAVIOUR	An anchor targeting `#forgot`. No such element or route exists. It changes the address fragment and nothing else.
CONSEQUENCE	A locked-out user presses the one control that appears to help them and gets no feedback at all. Support load falls on administrators with no prompt telling the user to contact one.
REMEDY	Replace with guidance text naming the assisted-reset procedure, or build the flow. The email service and templates already exist.
DOCUMENTED	User Manual §3.4; Training Manual EX–24 step 2.

F–11 Notification preferences are saved but have no channel — MEDIUM

WHERE	Notification Centre, lower half.
BEHAVIOUR	Email Alerts, SMS Alerts, Push Notifications, three per-category channel matrices, and a digest frequency are all persisted — to browser storage. Nothing on the server reads them, and no email, SMS, or push channel exists for any of these events. The only outbound message SERVMS ever sends is the password-reset notice to a fixed HQ mailbox, which these settings do not control.
CONSEQUENCE	The panel represents a complete alerting subsystem that does not exist. Its presence is worse than its absence: a user who enables Email Alerts for Financial Audits reasonably stops checking the Dashboard.
REMEDY	Hide the panel until a channel exists, or label it clearly as forthcoming. Then implement server-side delivery driven by the same rules the in-app feed already computes.
DOCUMENTED	User Manual §19.4; Training Manual EX–24 step 6 and the non-negotiable assessment items.

F–12 “Reset to Default” does not reset to a default — LOW

WHERE	Role Management, above the permission matrix.
BEHAVIOUR	Re-reads the currently saved permissions from the server, discarding unsaved changes on screen. No default matrix is stored anywhere, so none can be restored.
CONSEQUENCE	An administrator who has just saved a damaging change presses this button expecting recovery and gets confirmation of the damage instead. There is no undo for a permission save.
REMEDY	Rename to “Discard Changes”. Separately, consider seeding a stored default matrix so a genuine reset becomes possible.
DOCUMENTED	User Manual §8.5; Training Manual EX–08 and §11.1.

F–13 Two unreachable placeholder screens — LOW

WHERE	`SettingsPage.tsx` and `HelpCenterPage.tsx`.
BEHAVIOUR	Both are complete components with a heading and one line of placeholder text. Neither is registered as a route and neither has a menu entry, so neither can be opened by any means. Both addresses fall through to the Dashboard.
CONSEQUENCE	Dead code implying a settings and help capability that does not exist. SERVMS has no settings screen; the only user-adjustable preferences anywhere are the inert notification ones from F–11.
REMEDY	Delete both, or complete and route them.
DOCUMENTED	User Manual §5.3; Training Manual EX–24 step 9.

F-14 “Export Summary” downloads raw JSON — LOW

WHERE	Reports hub, top right.
BEHAVIOUR	Serialises the four on-screen metric objects and downloads them as `servms-report-summary.json`.
CONSEQUENCE	Beside a Report Builder producing CSV and XLSX, a button labelled “Export Summary” that yields a developer-oriented data file is misleading. It cannot be opened by its likely audience.
REMEDY	Produce a formatted summary in CSV or XLSX, or remove the button.
DOCUMENTED	User Manual §17.1.

SECTION 7

Not Implemented

Capabilities with no working path in either layer.

CAPABILITY	STATUS	SEVERITY
Self-service password reset	Absent. The login control is inert (F–10); the assisted two-person flow is the only route.	MEDIUM
Self-service password change	Endpoint exists, no screen (F–08).	HIGH
Global cross-module search	Absent. The top-bar field is inert (F–09).	MEDIUM
Outbound email, SMS, push notification	Absent for every business event. Only the password-reset request notice is sent, to a fixed address (F–11).	MEDIUM
Login / logout audit entries	Absent. The filter offers them; no controller writes them (F–16).	HIGH
Multi-factor authentication	Absent. Username and password only.	MEDIUM
Account lockout after failed attempts	Absent. Sign-in attempts are unlimited and unrecorded.	MEDIUM
Password complexity, expiry, reuse prevention	Absent. Six-character minimum is the only rule.	MEDIUM
Idle session timeout; server-side revocation	Absent. Tokens are valid for 12 hours regardless of activity and cannot be revoked.	LOW
Settings screen	Absent and unreachable (F–13).	LOW
Help / support screen	Absent and unreachable (F–13).	LOW
Dropdown / master-data administration screen	Absent; endpoints and permission exist (F–07).	MEDIUM
User-selectable column sorting	Absent on every listing. Order is fixed server-side.	LOW
Bulk import for vendors, contractors, units, trains, clusters, users	Absent. Stations is the only importable master.	MEDIUM
Read-access auditing	Absent. The trail records changes, not views.	LOW
Vendor or contractor self-service portal	Absent by design. Staff-only, plus the public verification page.	BY DESIGN

SECTION 8

Inconsistencies Between Layers

F-15 Account status is not checked at sign-in — HIGH

LAYERS	Database defines four statuses — active, inactive, suspended, pending_approval. The UI exposes a Toggle action and renders the status prominently. The authentication path reads none of it.
BEHAVIOUR	The login lookup selects the user by username and verifies the password. It does not filter or test `users_status` at any point. A user set to Inactive, Suspended, or Pending Approval signs in normally and operates with full role permissions.
CONSEQUENCE	Deactivation is presentational. The one control an administrator would use to remove a departing member of staff's access does not remove it, while displaying a badge that says it has. This is the most consequential defect in the system: it is silent, it looks like it worked, and the failure only becomes visible if someone tests it.
REMEDY	Reject sign-in for any status other than `active`, with a distinct message. Consider also rejecting requests whose token belongs to a since-deactivated account.
DOCUMENTED	User Manual §3.7, §7.3, §22.7, §23.3, and the FAQ; Training Manual EX–24 step 5 and a non-negotiable assessment item.

F-16 Audit filter offers eight actions that are never written — HIGH

LAYERS	The audit service defines 22 action types. The Audit Logs screen offers 17 of them as filters. Only 14 are ever written by a controller.
BEHAVIOUR	`LOGIN`, `LOGOUT`, `DOWNLOAD`, `PRINT`, `PASSWORD_RESET`, `RECOVER`, `RENEW`, and `ISSUE` appear in the filter and are written nowhere. Most seriously, the login controller updates the last-login timestamp and issues a token without writing any audit entry.
CONSEQUENCE	**Sign-ins and sign-outs are not recorded anywhere.** The only trace of a sign-in is the “Last Login” column, which holds one timestamp and is overwritten each time. There is no way to establish who accessed the system, when, or from where — and no way to detect use of a compromised account. An auditor filtering for Login receives an empty result that reads as “no sign-ins occurred”.
REMEDY	Write a `LOGIN` entry on success (and on failure, which would also give the missing basis for lockout), a `LOGOUT` entry on sign-out, and `PASSWORD_RESET` on reset approval. Remove filter options for actions that remain unwritten.
DOCUMENTED	User Manual §20.4 as a prominent gap; Training Manual EX–23 step 12 makes trainees observe it.

F-17 Sub Admins are entitled to manage type masters but cannot see the buttons — MEDIUM

LAYERS	Server: complaint and inspection type management is gated on an explicit role list — HQ Admin, Divisional Admin, **HQ Sub Admin, Divisional Sub Admin**. UI: the Complaints screen gates its button on `admin_module: create` or `complaint_management: approve_reject`; the Inspections screen on `inspection_management: approve_reject`.
BEHAVIOUR	Neither Sub Admin role holds any of those permissions, so neither sees either button — despite being explicitly permitted by the server.
CONSEQUENCE	A documented entitlement is unreachable for two of the eight roles. Type-master maintenance falls entirely to the Admin tier, contrary to the intended delegation. This also matters operationally: RailMadad imports create complaint types automatically, and curating them is exactly the kind of task a Sub Admin should own.
REMEDY	Gate both buttons on the same role list the server uses.
DOCUMENTED	User Manual §14.8 and §15.9; Training Manual §4.3, §4.5, and EX–24 step 10.

F-18 Client API base address does not match the server port — MEDIUM

LAYERS	`client/.env` sets the API base to port 5000. `server/.env.example` and the README both specify port 4000, and the README explicitly notes that 4000 was chosen to avoid a conflict on macOS. The compiled default in the client source points at a production host.
CONSEQUENCE	A developer following the README gets a client that cannot reach its API, with network errors and no explanatory message. Three sources disagree about a single value.
REMEDY	Align `client/.env` with the documented port and remove the production host as a compiled-in fallback.

F-19 README describes a setup that does not exist — MEDIUM

LAYERS	The README instructs the reader to run `server/database/setup.sql`, describes a 16-table schema, and lists `superadmin` as the Super Admin username. The repository actually contains `server/db_schema.sql` with 38 tables and a `seed.ts` script, and the seeded Super Admin username is `superadminhq`.
CONSEQUENCE	The published setup path fails at the first command. The documented sign-in credential is wrong. A new starter cannot get the system running from the README alone.
REMEDY	Rewrite the database setup section against the current schema file and seed script, and correct the credential table.

F-20 Uploaded documents are publicly readable — MEDIUM

LAYERS	Every upload — Aadhaar scans, medical certificates, police verification reports, penalty recovery receipts, generated ID card PDFs — is written to a directory served as unauthenticated static content.
BEHAVIOUR	Anyone holding a document address can open it without signing in. Names include a timestamp so they are not trivially guessable, but they are also not protected, and the addresses appear in the browser and in shareable links.
CONSEQUENCE	The permission matrix and division scoping govern who can find a document, not who can read one. A link forwarded outside the intended audience discloses the file. Vendor identity documents and generated ID cards are the most sensitive material in the system.
REMEDY	Serve uploads through an authenticated route that checks the requester's permission and division scope against the owning record.
DOCUMENTED	User Manual §21.4 and §23.4.

F-21 QR payload carries full Aadhaar and address in plain text — MEDIUM

LAYERS	The QR text encodes the vendor's name and address, full Aadhaar number, both verification validity dates, unit, vendor type, contractor, card validity, issuing authority, a verification link, and a status-sheet link. The public verification page independently displays the full Aadhaar and address to anyone who opens it.
BEHAVIOUR	Scanning a printed card with any QR reader yields the full payload without contacting SERVMS at all. Format 1 masks the Aadhaar in its printed body — but the QR beside it does not.
CONSEQUENCE	A printed vendor ID card is a self-contained disclosure of that vendor's Aadhaar number and home address. The masking on Format 1 gives a false impression of protection.
REMEDY	Reduce the QR payload to the card number and the verification link, and let the authenticated-or-limited verification page decide what to reveal. Mask the Aadhaar on the public page.
DOCUMENTED	User Manual §12.6, §12.7, §23.5; Training Manual EX–18 and a non-negotiable assessment item.

F-22 Two “Excel” buttons produce CSV — LOW

BEHAVIOUR	Vendor Management's *Export to Excel* and Audit Logs' *Export Excel* both build CSV. Complaints, Inspections, and the Report Builder produce genuine `.xlsx` workbooks.
CONSEQUENCE	Both open correctly in Excel, so the impact is cosmetic — but inconsistent labelling across a single application undermines confidence in the rest of it.
REMEDY	Relabel, or produce XLSX using the workbook writer already present.
DOCUMENTED	User Manual §18.4.

F-23 Vendor and Penalty exports truncate silently at 2,000 rows — LOW

BEHAVIOUR	Both exports request a fixed limit of 2,000 rows. If the filtered set is larger, the file simply stops. No warning, no indication in the file, no row count shown.
CONSEQUENCE	An incomplete extract that looks complete. A division with more than 2,000 vendors would produce a truncated compliance report with nothing to signal it.
REMEDY	Paginate through the full set, or warn when the total exceeds the cap.
DOCUMENTED	User Manual §18.4 and the FAQ; Training Manual §8.3.

F-24 Notification read state is per-browser, not per-user — LOW

BEHAVIOUR	Read notification identifiers are kept in browser storage. Nothing is sent to the server.
CONSEQUENCE	The unread badge differs between a user's own machines and resets when browser data is cleared. Two people sharing a workstation share each other's read state.
REMEDY	Persist read state per user on the server, or accept and document the limitation as a deliberate simplification.
DOCUMENTED	User Manual §19.3.

F-25 Dashboard licence-fee figures link to a screen that cannot reproduce them — LOW

BEHAVIOUR	Three Pending Action sub-groups — licence fee due within 7 days, within 14 days, and overdue — navigate to Location & Unit Management with a division filter only. That screen has no licence-fee filter.
CONSEQUENCE	The figure clicked and the list arrived at do not correspond, with nothing on screen to explain why. The user cannot act on the number they were shown.
REMEDY	Add a licence-fee-due filter to the Units tab and thread it through the link.
DOCUMENTED	User Manual §4.4; Training Manual EX–03.

F-26 Contractor status enum is inconsistent between create and change-status — LOW

BEHAVIOUR	Create and update validation accept active, pending_approval, suspended, and expired. The change-status action additionally accepts blacklisted, and the client type declares all five. Blacklisting is therefore reachable only through the dedicated status action — which is deliberate, and mirrors the vendor module.
CONSEQUENCE	Correct behaviour, but not evident from the type definitions alone. Worth an explicit note in the schema.
REMEDY	Document the intent in the validation file, as the vendor module already does.

F–27 Identity fields validated on length only — LOW

BEHAVIOUR

Aadhaar is checked for exactly 12 characters — not that they are digits. PAN is checked for exactly 10 characters, GSTIN for exactly 15, neither against its known format. Mobile numbers are trimmed and otherwise unchecked, on both users and vendors, despite being mandatory on both forms.

CONSEQUENCE

Transcription errors pass validation and reach the database. Since vendors have no edit screen (F–02), a mistyped Aadhaar is permanent — and it is printed on the ID card and encoded in the QR.

REMEDY

Apply format patterns to Aadhaar, PAN, GSTIN, and mobile. Low effort, and it compounds with F–02.

F–28 Record codes generated from a random number rather than a sequence — LOW

BEHAVIOUR

Vendor codes are `V-2026-` plus a random four-digit number; complaint codes and penalty codes follow the same pattern. Contractor codes and inspection numbers, by contrast, use proper counters — `CON-001` and `INSP-2026-000001`.

CONSEQUENCE

Only 9,000 distinct vendor codes exist per year. Collisions become likely well before that — at around 100 vendors the chance of a duplicate is roughly one in two. A collision surfaces as an opaque database error at the end of the wizard, and the vendor year prefix is hard-coded to 2026.

REMEDY

Use the same counter approach as inspection numbers for vendors, complaints, and penalties, and derive the year from the current date.

SECTION 9

Dormant Database Fields

Columns that are stored but never written by a form and never read by a screen. Each is a small maintenance liability and a source of confusion when reading the schema.

TABLE	COLUMN	STATUS
contractors	`compliance_rate`	Declared in the client type; on no form, no detail view, no listing, no report
contractors	`penalty_index`	Same — no write path, no read path
contractors	`irctc_licensed`	Same
contractors	`joined_date`	Same. `award_date` serves the equivalent purpose and is used
units	`duration_type`	Explicitly marked legacy in the source, superseded by `contract_type`. Not on any form or screen
vendors	`father_name`, `date_of_birth`	Captured by the onboarding wizard, then displayed nowhere in the application
penalties	`penalties_status`	Legacy three-state column, kept synchronised server-side but superseded by the approval and recovery pair. Documented as legacy in the source
users	`is_temp_password`	Written on reset approval, then never read — see F–08
users	`users_status`	Written and displayed, but never read by the authentication path — see F–15
vendor_id_cards	`excel_status_link`	Read when present, but no screen can set it — see F–07 group
complaints, inspections	`assigned_to_user_id`	Accepted, validated, stored, and joined for display — but no form control ever sets it. See F–04

> NOTE
>
> Three entries in this table are dormant for a reason that matters: `is_temp_password`, `users_status`, and `assigned_to_user_id` are not unused fields but *unfinished features*. Each has a working write path and a missing read path, which is why they appear here and in Sections 4 to 8 both.

SECTION 10

Priority Findings

Ordered by consequence, not by effort. The first three change what the system is trusted to do; the remainder change how well it does it.

#	FINDING	WHY IT COMES FIRST	EFFORT
1	**F–15** Sign-in ignores account status	The control administrators use to remove access does not remove it, while showing a badge that says it has. Silent, and only detectable by testing.	Very low — one condition in the login path
2	**F–16** Sign-ins are not audited	No record of who accessed the system or when. Compounds F–15: a deactivated account's continued use leaves no trace either.	Low — three audit calls
3	**F–01** Vendor Renewals is unguarded	Any authenticated user can return an expired vendor to Active service. The widest privilege gap in the system.	Very low — four middleware additions
4	**F–08** No self-service password change	Machine-generated temporary passwords, relayed verbally, become permanent credentials.	Low — endpoint exists, needs a screen
5	**F–20** Uploads publicly readable	Identity documents and ID card PDFs sit outside the access model entirely.	Medium — authenticated file route
6	**F–21** Aadhaar and address in the QR	A printed card discloses both to any scanner. Format 1's masking implies protection that is not there.	Low — reduce the payload
7	**F–02**, **F–03** No edit screens for vendors or users	Twelve vendor fields and eleven user fields are permanent on entry. Compounds F–27.	Medium — UI only, endpoints exist
8	**F–11** Inert notification preferences	A user who enables alerts reasonably stops checking the Dashboard. The absence is safer than the illusion.	Very low to hide; high to implement
9	**F–09**, **F–10** Inert search and Forgot Password	The two most prominent controls a new user reaches for both do nothing.	Very low to remove; medium to build
10	**F–28** Random record codes	Vendor code collisions become likely at around 100 vendors per year, surfacing as an opaque error at the end of the wizard.	Low — reuse the existing counter pattern
11	**F–17** Sub Admin type-master buttons hidden	A documented entitlement is unreachable for two roles, and the curation task is exactly theirs.	Very low — align two conditions
12	**F–18**, **F–19** Setup documentation wrong	The published setup path fails at the first command and the documented credential is wrong.	Very low — documentation only

> QUICK WINS
>
> Findings 1, 2, 3, 11, and 12 are all very low effort and together close the two highest-severity security gaps, the widest privilege gap, a role entitlement, and the broken setup path. None requires new UI. They would be a well-shaped first change-set.

SECTION 11

Documentation Coverage

11.1 What the manuals cover

DELIVERABLE	COVERS
Part A — User Manual	24 sections. Every reachable screen, the complete permission matrix, all seven complaint statuses and nine inspection statuses, all three penalty state families, every form field with its validation, all four card states and both formats, six approval workflows, the full import and export inventory, ~60 catalogued error messages, security guidance, and 22 FAQ entries.
Part B — Training Manual	Nine sessions across three tracks, eight role curricula, 24 exercises with objective, demonstration, hands-on task, and expected result, 18 troubleshooting scenarios, a role-tiered assessment checklist, and trainer's notes on timing and common misconceptions.
Part C — this report	31 findings across six categories, a 29-area compliance matrix, dormant-field inventory, and a prioritised remediation order.

11.2 Traceability

Every gap in this report is reflected in both manuals, so no reader of either can form an inaccurate picture of what the system does.

FINDING	USER MANUAL	TRAINING MANUAL
F–01 Renewals unguarded	§6.4, §13	§4 role curricula
F–02 No vendor edit	§11.4, FAQ	§7.1, §7.2, EX–13, EX–24
F–03 No user edit	§7.3, FAQ	§7.2, EX–05, EX–24
F–04 No assignee control	§14.6, §15.6	EX–19
F–05 Contractor edit narrower	§10.3	§7.2, EX–12
F–06 No cluster edit	§9.4	§7.2, EX–09, EX–24
F–07 Admin Module unreachable	§5.2	§7.4
F–08 No password change	§3.4, §7.4	EX–07, EX–24, §9.1
F–09 Inert global search	§5.1, §22.7, FAQ	EX–24
F–10 Dead Forgot Password	§3.4, §22.7, FAQ	EX–24, §9.1
F–11 Inert notification preferences	§19.4, §22.7, FAQ	EX–24, §9.1, §10.6
F–12 Misleading Reset to Default	§8.5, §22.7	EX–08, §9.1, §11.1
F–13 Unreachable placeholders	§5.3, FAQ	EX–24
F–14 JSON Export Summary	§17.1	§8.3
F–15 Status not checked at sign-in	§3.7, §7.3, §22.7, §23.3, FAQ	EX–24, §9.1, §10.6, §11.1, §11.3
F–16 Sign-ins not audited	§20.4, §22.7, FAQ	EX–23, §10.5
F–17 Sub Admin buttons hidden	§14.8, §15.9	§4.3, §4.5, §7.4, EX–24
F–20 Public uploads	§21.4, §23.4	§9.1

FINDING	USER MANUAL	TRAINING MANUAL
F–21 Aadhaar in QR	§12.6, §12.7, §23.5	EX–18, §10.6
F–22 Excel buttons produce CSV	§18.4, FAQ	EX–23, §8.3
F–23 Silent 2,000-row cap	§18.4, FAQ	§8.3, §9.1, §11.1
F–24 Per-browser read state	§19.3, FAQ	§9.1
F–25 Licence-fee drill-through	§4.4, §22.7, FAQ	EX–03, §8.2

11.3 Deliberately excluded

No credential, secret, key, connection string, or internal address appears in any of the three documents. Security findings are stated in terms of what a user must do differently, not in terms of how to exploit them. The two authentication findings (F–15, F–16) are documented because staff must know that deactivation does not remove access and that sign-ins leave no trail — withholding either would leave readers relying on a control that does not work.

11.4 Documentation review triggers

Any of the following changes invalidates part of the manuals and should trigger a revision:

- A change to the seeded permission matrix — User Manual §6.3 states it exactly.
- A new role, module, or permission action.
- Remediation of any finding in Section 10 — each is documented as a current limitation and several appear in the training assessment.
- A new screen, or a screen removed from the navigation.
- A change to any workflow's state machine — complaint, inspection, penalty, ID card, or renewal.
- A change to upload types or size limits.